COMPTIA SECURITY+ SY0-701 | DOMAIN 3 · SECURITY ARCHITECTURE (18%)

Security+ 3.3 · Data Types & Classifications

Mestre CyberSec · **Lesson 3.3 — Data Types & Classifications** (5:54) · Assistir Vídeo no YouTube ↗ · Treino Interativo: edusouzamarques.github.io/cybersec

Executive Lesson Summary: Classificar o dado: PUBLIC (nada perde); INTERNAL (apenas dentro); CONFIDENTIAL (estratégia, PII — fuga = dano grave); RESTRICTED (trade secret — fuga=catastrófico). A classificação DETERMINA o controle. PHI=dado de saúde; PCI-DSS=cartão.

💡 Key Exam Highlights & Critical Concepts

- Classificação determina QUAL proteção cada dado recebe
- PHI = saúde; PCI-DSS = cartão; PII = dados pessoais

🎯 Exam Tips & Typical CompTIA Scenarios

- 'least restrictive classification'=public; 'most restrictive'=restricted

🚨 Beyond the Video: Official Exam Concepts, Protocols & Traps (Section 3.3 — Data Types & Classifications)

Why is this advanced coverage required for SY0-701?: Video lectures provide foundational concepts, but CompTIA tests practical engineering judgment and requires deep familiarity with the following protocols, acronyms, and operational nuances in this domain:

• Public Data (N/A)

Information approved for release to anyone with no expectation of confidentiality; disclosure causes no damage.

⚠ ***Exam Trap:*** *Gatilho: 'least restrictive classification' = Public. Se puder ser compartilhado livremente, é Public.*

• Internal Data (N/A)

Information intended only for use within the organization; unauthorized disclosure may cause limited operational or reputational harm.

⚠ ***Exam Trap:*** *Gatilho: uso apenas dentro da empresa, nem público nem altamente sensível. Não confundir com Public.*

• Confidential Data (N/A)

Sensitive information such as business strategy or PII; unauthorized disclosure can cause serious damage to the organization or individuals.

⚠ ***Exam Trap:*** *Gatilho: PII, estratégia, planos internos = Confidential. Fuga gera dano grave.*

• Restricted Data (N/A)

Most sensitive classification, including trade secrets; unauthorized disclosure causes catastrophic damage and requires the strictest controls.

⚠ ***Exam Trap:*** *Gatilho: 'most restrictive classification' = Restricted. Trade secret/fuga catastrófica = Restricted.*

• Personally Identifiable Information (PII)

Data that can identify a specific individual, such as name, SSN, or biometrics; often classified as Confidential and protected by privacy laws.

⚠ ***Exam Trap:*** *Gatilho: PII = dados pessoais; se vazar, geralmente é Confidential com dano grave.*

• Protected Health Information (PHI)

Health information that identifies an individual and is protected under regulations such as HIPAA; requires strict privacy and security controls.

⚠ ***Exam Trap:*** *Gatilho: PHI = dado de saúde. Se a questão citar HIPAA ou prontuário, pense PHI.*

• **Payment Card Industry Data Security Standard (PCI-DSS)**

Security standard for organizations that store, process, or transmit cardholder data; noncompliance can lead to fines and loss of payment processing.

⚠️ ***Exam Trap:*** *Gatilho: PCI-DSS = cartão/cardholder data. Não é uma classificação, é um padrão de compliance.*

• **Data Classification (N/A)**

Process of labeling data based on sensitivity and value so that appropriate security controls and handling procedures are applied.

⚠️ ***Exam Trap:*** *Gatilho: a classificação DETERMINA o controle. Primeiro classifique, depois aplique proteção proporcional.*

🏛️ Conceptual Deep Dive, Real-World Analogies & GRC Analysis

📌 Corporate Data Classification Levels (Public, Internal, Confidential, Restricted)

🏠 **Real-World Analogy:** Think of the mail and access system in a high-security commercial tower. Promotional brochures at the reception desk are 'Public' (anyone walking past can grab one with zero harm). The breakroom bulletin board showing cleaner schedules and office extensions is 'Internal' (not a lethal secret, but not meant for pedestrians outside). Signed office lease agreements and expense ledgers locked in the property manager's file cabinet are 'Confidential' (unauthorized leaks trigger lawsuits and severe financial injury). Finally, the blueprints of the security ventilation shafts and master vault combinations are 'Restricted/Secret' (accessible only to executive directors; disclosure poses an existential, catastrophic crisis).

🔍 **Root Cause & Background:** Catastrophic data breaches happen when enterprises treat all documents identically without identifying high-risk assets, or conversely fall into over-classification—marking every memo 'Top Secret', which paralyzes business workflows and drives frustrated workers toward unapproved Shadow IT workarounds.

🛡️ **GRC Auditor Perspective:** The auditor inspects the formal Data Classification Policy and role assignments: Data Owner (sets sensitivity levels and approves access) and Data Custodian (implements storage, encryption, and backup controls). Audits enforce automated metadata tagging, visual document watermarking, and mandatory user training.

⚠️ **How CompTIA Tests This:** Exam trigger: 'least restrictive classification level' = Public (zero damage upon disclosure). 'Highest impact causing catastrophic/existential harm' = Restricted / Secret / Top Secret. Distractor trap: distinguishing government/military classification tiers (Unclassified, Confidential, Secret, Top Secret) from commercial tiers (Public, Internal, Confidential, Restricted).

📌 PII (Personally Identifiable Information) vs PHI (Protected Health Information)

🏠 **Real-World Analogy:** Your government ID card and driver's license dropped on a retail counter represent PII: they directly pinpoint who you are in the public and commercial registry. In contrast, your sealed hospital medical record containing blood test outcomes, psychiatric evaluations, and biopsy diagnoses represents PHI: it not only identifies you, but exposes the most vulnerable biological and clinical realities of your person.

🔍 **Root Cause & Background:** The automated aggregation of disparate digital databases enables bad actors to execute identity theft and bank fraud via PII, while medical dossiers (PHI) fetch ten times higher payouts on darknet markets because health histories are irreversible and fuel fraudulent insurance claims and extortion.

🛡️ **GRC Auditor Perspective:** Auditing adherence to statutory privacy frameworks: GDPR and LGPD for general PII, enforcing Data Protection Impact Assessments (DPIA) and data subject erasure rights; and HIPAA/HITECH for PHI, demanding unalterable access logs for electronic medical records and mandatory encryption.

⚠️ **How CompTIA Tests This:** Exam trigger: 'patient diagnosis, medical chart, lab test results, clinical records' = PHI (governed under HIPAA). Trigger: 'social security number, biometric facial scan, driver's license, home address' = PII. Remember: all PHI is personal data, but subject to stringent healthcare regulations.

📌 Intellectual Property (IP) & Trade Secrets

🏠 **Real-World Analogy:** The guarded formula of Coca-Cola syrup kept in a subterranean vault in Atlanta, or the proprietary aerodynamic CAD blueprints and engine telemetry of a Formula 1 racing team. If a rival steals that blueprint, the company instantly loses decades of competitive dominance and billions in market valuation.

🔍 **Root Cause & Background:** The friction-free capability to siphon gigabytes of source code, patent designs, and manufacturing schematics onto a tiny USB stick in seconds, or exfiltrate them via personal webmail by departing disgruntled insiders or state-sponsored corporate spies.

🛡️ **GRC Auditor Perspective:** Auditing Non-Disclosure Agreements (NDAs), IP protection clauses in employment contracts, rigorous automated offboarding de-provisioning, and network segmentation (air-gapped or isolated VLANs) protecting R&D repositories.

⚠️ **How CompTIA Tests This:** Exam trigger: 'trade secrets, proprietary software codebases, engineering schematics, patents conferring market edge' = Intellectual Property (IP). Distractor: do not confuse with public consumer PII.

📌 Financial Data & Payment Card Industry Standards (PCI-DSS)

🏠 **Real-World Analogy:** The POS credit card terminal and paper receipt at a restaurant. The establishment is entitled to receive settlement for your meal, but if the waiter pulls out a notepad and scribbles down your full 16-digit Primary Account Number (PAN) along with the 3-digit security code on the back (CVV/CVC), they are committing a catastrophic breach of payment industry laws.

🔍 **Root Cause & Background:** Global card-cloning epidemics and fraudulent Card-Not-Present (CNP) e-commerce transactions, prompting major card brands (Visa, Mastercard, Amex) to establish mandatory security baseline penalties and revocation of payment gateway privileges for negligent merchants.

🛡️ **GRC Auditor Perspective:** Auditing PCI-DSS (Payment Card Industry Data Security Standard) compliance; verifying strict network isolation of the Cardholder Data Environment (CDE); enforcing the GOLDEN RULE: CVV/CVC security codes must NEVER be stored at rest post-authorization under any circumstance.

⚠️ **How CompTIA Tests This:** Exam trigger: 'company processes, transmits, or archives payment card accounts (PAN) and billing details' = PCI-DSS compliance. Absolute exam trap: if asked which data element can NEVER be retained in storage post-authorization, the answer is CVV/CVC or full magnetic track data.

⚡ QUICK-REFERENCE EXAM CHEAT SHEET

Typical Exam Scenario / Practical Situation	Technical Concept & Target Answer
Intentional public release of marketing flyers or corporate press statements causing zero operational damage	**Public Data**
Exposure of internal staff rosters and departmental charts causing workplace friction and embarrassment	**Internal / Private Data**
Leak of unreleased financial audits, vendor supplier contracts, and client lists causing severe legal and financial injury	**Confidential Data**
Compromise of algorithmic high-frequency trading code or root cryptographic private keys threatening organizational survival	**Restricted / Secret Data**
Patient medical histories, laboratory diagnosis findings, and medical insurance billing under health mandates	**Protected Health Information (PHI / HIPAA)**
Citizen social security numbers, biometric facial records, home addresses, and personal phone logs under privacy mandates	**Personally Identifiable Information (PII - GDPR/LGPD)**

✅ Authentic Practice Questions (10 Real Exam Scenarios)

Scenario-based exam questions. Complete explanations and distractor analysis are provided in the answer key below.

QUESTION 1 · EXAM SCENARIO

A hospital stores patient names, diagnoses, medication histories, and insurance identifiers in a clinical records system. The security team must document the regulated data type represented by this dataset. Which data type is it?

A) Public data across all enterprise cloud environments

B) Personally identifiable information (PII)

C) Protected health information (PHI)

D) Payment card data across all internal corporate clusters

QUESTION 2 · EXAM SCENARIO

An HR system contains employee Social Security numbers, home addresses, dates of birth, and emergency contact details. Which data type is represented?

A) Personally identifiable information (PII)

B) Public data to preserve network topology and payload integrity

C) Protected health information (PHI) across all internal corporate clusters

D) Payment card data during scheduled administrative maintenance windows

QUESTION 3 · EXAM SCENARIO

A retail payment application processes customer primary account numbers, expiration dates, and service codes during checkout. Which regulated data type applies to this information?

A) Personally identifiable information (PII) to preserve network topology and payload integrity

B) Payment Card Industry Data Security Standard (PCI-DSS) data

C) Protected health information (PHI) during scheduled administrative maintenance windows

D) Public data before forwarding requests to backend services

QUESTION 4 · EXAM SCENARIO

A company posts its annual sustainability report on an externally accessible website so that anyone can download it without authentication. Under a four-level policy of Public, Internal, Confidential, and Restricted, how should this report be classified?

A) Internal

B) Confidential

C) Restricted

D) Public

QUESTION 5 · EXAM SCENARIO

A directory of employee names and work extension numbers is accessible only from the corporate network and is not shared with customers, vendors, or the public. How should this directory be classified under a four-level policy of Public, Internal, Confidential, and Restricted?

A) Internal

B) Public before forwarding requests to backend services

C) Confidential

D) Restricted

QUESTION 6 · EXAM SCENARIO

A marketing database contains customer names, email addresses, order histories, and loyalty account numbers. Unauthorized disclosure would cause serious reputational and regulatory harm to the company. Under a four-level policy of Public, Internal, Confidential, and Restricted, how should this database be classified?

A) Public before forwarding requests to backend services

B) Internal while enforcing strict least-privilege policies

C) Confidential

D) Restricted to ensure continuous high availability and compliance

QUESTION 7 · EXAM SCENARIO

A technology company stores source code and design documents for an unreleased product that uses proprietary algorithms. Disclosure would give competitors a major advantage and cause catastrophic financial loss. Under a four-level policy of Public, Internal, Confidential, and Restricted, how should this material be classified?

A) Public while enforcing strict least-privilege policies

B) Internal to eliminate single points of failure across endpoints

C) Confidential

D) Restricted

QUESTION 8 · EXAM SCENARIO

An employee needs to share a memo with an external consultant. The memo is currently labeled for internal use only and contains no PII, PHI, payment card data, or trade secrets. According to classification-driven handling, what should the employee do first?

A) Upload it to the public website and send the URL to the consultant

B) Request a policy exception or reclassification before sharing it externally

C) Encrypt it with a personal password and send it from a personal email account

D) Post it on the internal collaboration site and give the consultant a VPN account

QUESTION 9 · EXAM SCENARIO

A hospital must send protected health information to a billing vendor for claims processing. Which control set best aligns with the data's classification and regulatory requirements?

A) Use encrypted transfer, a business associate agreement, least-privilege access, and audit logging

B) Label the data as public and post it to a public portal for vendor download across all perimeter demilitarized zone boundaries

C) Convert the data to PDF and send it through regular email without encryption across all enterprise cloud environments

D) Store the data on an internal file share and give the vendor a shared local account without altering existing firewall rules

QUESTION 10 · EXAM SCENARIO

A cloud storage bucket contains publicly releasable marketing PDFs, internal policy documents, and customer account records with PII. The security team must apply the company's data classification policy to the bucket's contents. Which approach is most appropriate?

A) Label the entire bucket as public because some files are safe for release across all perimeter demilitarized zone boundaries

B) Label the entire bucket as confidential because some files contain PII across all enterprise cloud environments

C) Encrypt the bucket once and give all employees access to simplify management without altering existing firewall rules

D) Apply per-object classification labels and enforce access controls and DLP based on each label

ANSWER KEY & COMPREHENSIVE DISTRACTOR EXPLANATIONS

Question 1: Option C — Protected health information (PHI)

Correct: PHI. The dataset combines health information with identifiers, so it is protected health information under HIPAA. PII is broader personal data but does not specifically cover health treatment information; public and payment card data are incorrect because the records are neither openly shareable nor cardholder data.

Question 2: Option A — Personally identifiable information (PII)

Correct: PII. These fields can identify a specific individual and require protection. PHI applies to health information, payment card data applies to cardholder data, and public data would not require privacy controls.

Question 3: Option B — Payment Card Industry Data Security Standard (PCI-DSS) data

Correct: PCI-DSS data. Cardholder data such as PAN, expiration date, and service code is governed by PCI-DSS. PII and PHI are different regulated categories, and public data has no such protection requirements.

Question 4: Option D — Public

Correct: Public. The data is intended for open release and its disclosure causes no harm. Internal data is not for external release, Confidential data would cause serious harm if exposed, and Restricted data would cause catastrophic harm.

Question 5: Option A — Internal

Correct: Internal. It supports internal operations and should remain inside the organization, but its exposure would not cause serious or catastrophic harm. Public would allow open release, while Confidential and Restricted require stronger protection.

Question 6: Option C — Confidential

Correct: Confidential. Customer PII and account-related data generally require protection because exposure causes serious harm. Restricted is reserved for trade secrets or data whose loss is catastrophic. Public and Internal do not fit because the data is sensitive and not merely internal operational information.

Question 7: Option D — Restricted

Correct: Restricted. The material is a trade secret whose exposure would cause catastrophic harm. Confidential covers serious harm such as PII exposure, while Internal and Public would provide far too little protection.

Question 8: Option B — Request a policy exception or reclassification before sharing it externally

Correct: Request a policy exception or reclassification. Internal data is intended for internal use, so external sharing requires approval and possibly a new label with appropriate controls. Public posting is unauthorized, personal email bypasses policy, and giving an external party VPN access changes access without addressing classification.

Question 9: Option A — Use encrypted transfer, a business associate agreement, least-privilege access, and audit logging

Correct: Use encrypted transfer, a BAA, least-privilege access, and audit logging. PHI is regulated and highly sensitive, so it requires strong technical and administrative safeguards. Public posting, unencrypted email, and shared local accounts expose the data and violate HIPAA expectations.

Question 10: Option D — Apply per-object classification labels and enforce access controls and DLP based on each label

Correct: Apply per-object classification labels and enforce controls based on each label. A mixed bucket cannot be managed safely with a single blanket classification. Per-object labeling ensures public, internal, and confidential data receive the appropriate access, encryption, and monitoring controls.